

IBM 《Agentic Consent 详解：AI 智能体如何安全且负责任地行动》

AI 双语课 & Codex

2026-05-27



视频频道：AI 双语课

发布日期：2026-05-27

视频时长：14 分 10 秒

视频链接：<https://www.bilibili.com/video/BV1vjGJ6jE5H/>

字幕来源：B 站 AI 中文字幕（无英文字幕轨可用）

目录

1	从普通同意到知情同意	1
2	传统 IT 系统里的同意怎样落地	3
3	Agentic 环境把同意变成动态治理问题	4
4	细粒度权限：时间、交易与策略	6
5	即时同意、透明度与可撤销授权	8
6	总结与延伸	10

1 从普通同意到知情同意

1.1 智能体把“同意”从态度变成授权边界

视频开头先把问题放得很直：AI 智能体不会只生成一段文本，它会执行操作。只要系统开始代用户调用工具、访问数据、发起交易、修改状态，“同意”就不能停留在一句“用户愿意”。它必须回答四个工程问题：谁给了授权，允许做哪些动作，授权范围有多大，授权在什么时候失效。

这也是规模化部署智能体时绕不开的原因。单个演示里，人工盯住每一步还勉强可行；一旦智能体进入企业流程、客户数据和跨系统调用，授权边界就必须变成可复用、可审计、可撤销的机制。

同意的最小授权结构

在智能体系统中，一次有效同意至少包含授权主体、被授权行为、作用范围和有效期。缺少任意一项，后续执行都会出现解释空间，治理系统也难以判断某个动作是否越界。

普通意义上的同意，指一个人自愿接受另一个人的提议或愿望。这个定义看似日常，却已经包含两个关键条件：第一，接受者知道自己面对的提议；第二，接受行为由本人自愿完成。把它放进 AI 智能体场景后，提议的内容就变成了“智能体将要替用户做什么”。

1.2 明示同意与默示同意

视频用借车例子说明明示同意。某人请求借车，对方可以给出非常具体的条件：只能去商店，必须一小时内返回。借车人随后说“同意”，这个回答承接了前面所有条件。这里的重点不在“说了同意”这几个字，而在条件链条已经明确：行动是借车，范围是商店，期限是一小时。

默示同意则来自行为。视频里的商店监控例子很典型：门口有监控提示，顾客继续进入，系统可以把进入行为理解为对视频监控的接受。默示同意有一个更高风险的前提：提示必须足够清楚，环境也必须让人有合理选择。如果提示藏得很深，或者用户没有实际退出空间，默示同意就会变成薄弱证据。

默示同意的误区

默示同意依赖“清楚提示 + 可理解环境 + 可选择行为”。在智能体系统里，隐藏在后台的工具调用、跨服务数据流和自动策略更新，很难自然满足这些条件，所以不能把默示同意当成默认兜底。

1.3 知情同意的四个条件

视频随后给出 IT 语境里的知情同意：个人以明确、知情且自愿的方式，允许组织为了特定目的收集、处理或使用其信息。

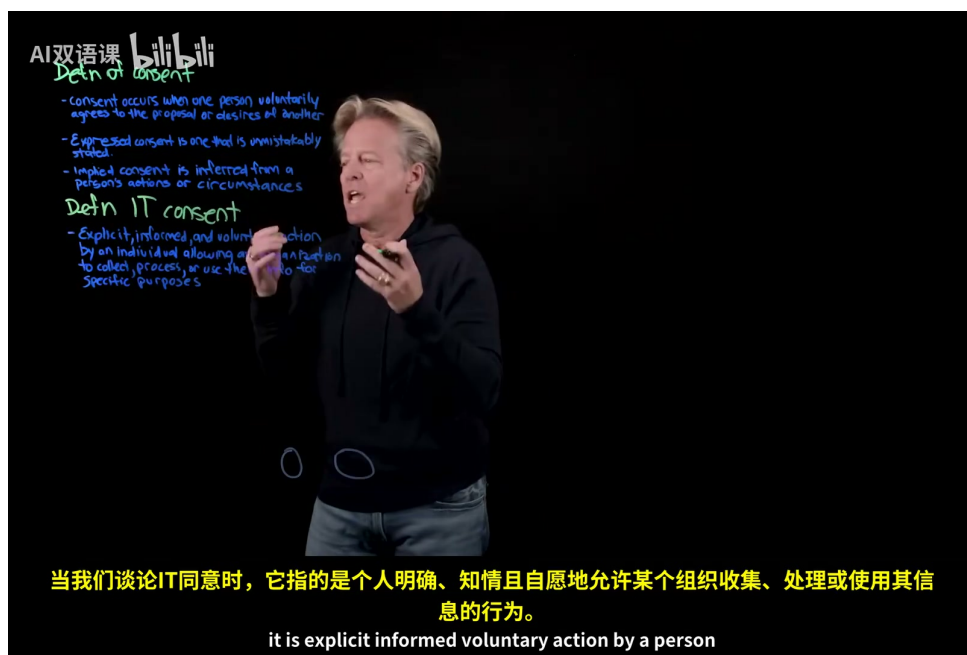


图 1: 讲者在白板上给出 IT consent 的核心定义：明确、知情、自愿，并且绑定特定目的。¹

这一定义可以拆成四个条件：

- **明确：** 用户需要做出清楚的肯定性动作，例如勾选复选框或点击接受按钮。
- **知情：** 系统要说明将收集什么数据、处理什么内容、执行什么动作。
- **自愿：** 用户拥有实际选择空间，授权不能来自强迫或伪选择。
- **特定目的：** 授权只服务于已经说明的目的，不能自动扩展到其他用途。

这四个条件共同构成后文的地基。智能体治理中的难点，恰恰来自这些条件在动态环境中会被拉扯：目的会变化，动作会扩展，调用链会变长，有效期也可能从一次请求滑向长期权限。

1.4 本章小结

本章建立了后续讨论的词汇基础。同意应被视为一组可检查的授权边界，而不能停在宽泛态度声明。明示同意强调清楚表达，默示同意强调可理解环境，知情同意则把“明确、知情、自愿、特定目的”合在一起。AI 智能体一旦开始执行动作，这些条件就必须进入系统设计，而不能只停留在法律或产品文案层面。

¹ 视频画面时间区间：00:02:05–00:02:14。

2 传统 IT 系统里的同意怎样落地

2.1 应用边界里的授权流程

传统 IT 系统里的同意通常发生在一个清楚的应用边界内：用户打开应用，组织展示需要收集的数据、处理目的和后续动作，用户通过按钮或复选框完成确认。这个流程的优点是上下文稳定，参与方较少，授权对象也比较容易写进界面和日志。

视频描述了一个典型场景：用户正在与应用程序交互，应用背后属于某个组织。组织需要用户允许它收集、处理或使用信息，于是展示一段说明，列出数据、操作和行为。用户点击接受按钮或勾选复选框，系统记录这次同意。

2.2 Cookie 提示展示了“目的绑定”

讲者用 Cookie 提示说明隐私法规下的同意实践。弹窗会说明它将收集信息，用于市场营销或后续联系。这个例子提醒读者，授权并不只关心“能不能收集”，还关心“为了什么目的收集”。

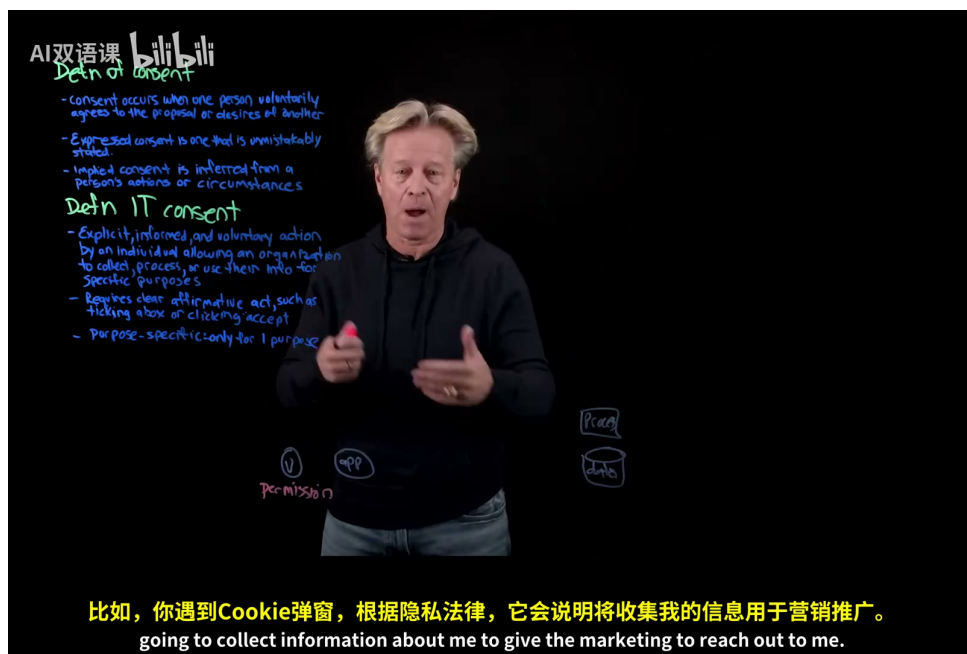


图 2: 传统 IT 同意模式：应用展示数据收集目的，用户通过按钮或复选框完成明确授权。²

目的绑定

目的绑定可以理解成“授权的用途锁”。用户允许系统为了某个目的使用数据，并不自动允许系统把同一份数据拿去做无关动作。对于智能体系统，这个原则会变得更关键，因为工具调用和下游任务可能把数据带到新的上下文里。

2.3 传统模式的工程假设

传统应用同意能够成立，依赖几个隐含假设：

- 交互界面稳定，用户能看到授权提示。

²视频画面时间区间：00:03:23–00:03:37。

- 应用要执行的动作大体可预测。
- 数据处理流程主要在组织自己的 IT 系统中完成。
- 授权记录和实际操作之间的距离较短，审计链条相对直接。

这些假设在普通网站、移动 App、企业后台里经常成立。到了智能体系统，它们会被削弱：智能体可以根据提示改变计划，可以调用 MCP 服务器，可以让其他智能体参与，也可能在任务进行到一半才遇到敏感信息。传统同意流程仍然有价值，但它只提供了起点。

从静态界面到执行系统

传统同意把重点放在“用户看见提示并点击确认”。智能体场景还要追问：确认以后，系统如何在每一次工具调用、数据访问和策略分支上持续检查授权边界。

2.4 本章小结

传统 IT 同意模式给出了一个清晰基线：说明数据、说明目的、要求肯定性动作、保存授权证据。它适合稳定应用边界，却难以覆盖动态智能体执行链。后续章节会把这个基线扩展到上下文感知、身份治理、细粒度权限和即时人工审核。

3 Agentic 环境把同意变成动态治理问题

3.1 动态性来自执行链条

当讨论进入智能体系统，视频明确指出：系统里没有固定的静态授权授予，也没有只靠一次点击就能解释所有后续动作的协议。智能体会读取用户目标，选择工具，调用 MCP 服务器，甚至调用其他智能体。环境变化时，决策机制也会变化，最初授予的权限可能已经无法覆盖新的作用范围。

这就是 Agentic Consent 的核心张力：用户授权的对象不再只是某个应用界面上的按钮动作，而是一条会继续展开的执行链。链条中每一步都可能改变风险，例如从读取普通信息变成读取财务信息，从一次查询变成长期自动化，从单一应用变成跨服务协作。

3.2 上下文感知与动态场景处理

讲者提出的第一个要求是上下文感知。系统必须知道智能体运行在什么任务里，用户希望达成什么目标，当前步骤要访问哪些资源，以及这些资源是否敏感。没有上下文，治理系统只能看到“某个工具调用发生了”，却很难判断它是否仍在授权范围内。

第二个要求是处理变化场景。生成式技术带有非确定性，智能体可能根据中间结果调整下一步行动。一个应用先调用智能体 A，智能体 A 又调用智能体 B 或 MCP 服务，实际动作可能超出最初界面提示的直观范围。治理系统因此需要持续评估，而不能把第一次授权当成永久通行证。

3.3 身份治理是控制平面

视频把身份管理放在核心位置。身份治理系统要识别用户身份，也要验证智能体身份，并理解智能体的操作意图。这里的“身份”已经超出用户名这类静态标签，更像执行链上的控制平面：谁在请求，哪个智能体在执行，代表谁执行，打算访问什么资源，是否可以证明这次动作得到授权。

³视频画面时间区间：00:07:31–00:07:52。

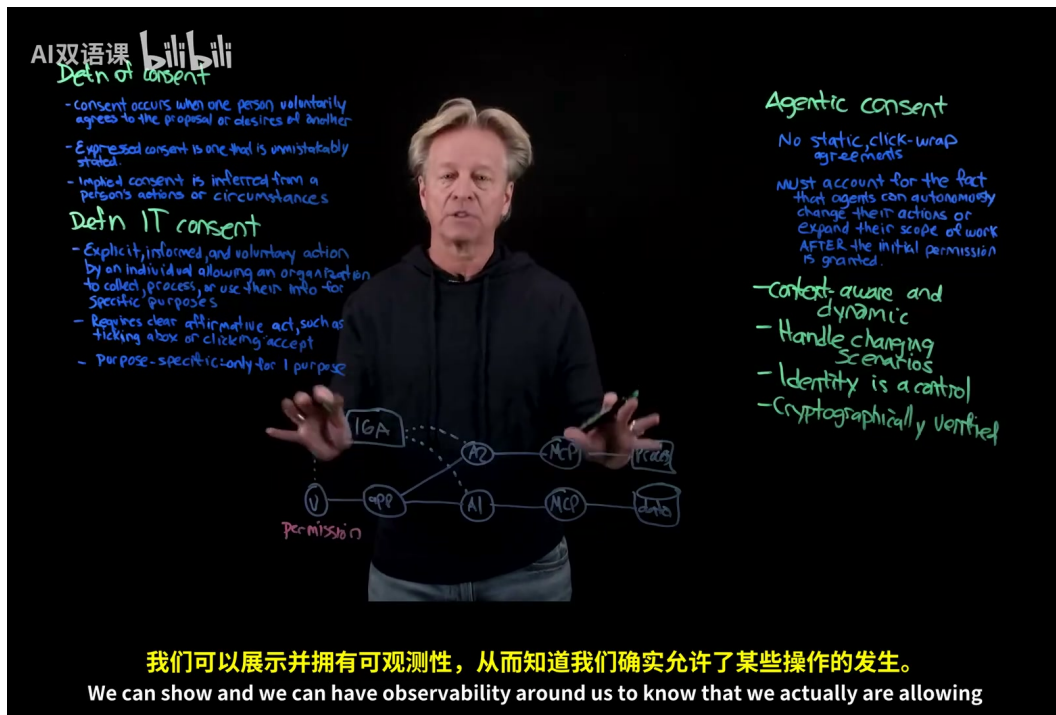


图 3: Agentic Consent 的控制点：上下文感知、动态场景、身份作为控制面、密码学验证和可观测性。³

身份提供商与智能体身份

在传统登录系统里，身份提供商主要验证人。智能体系统还需要给代理、工具调用和服务端组件建立可验证身份。否则审计日志只能看到“系统做了某事”，却很难追溯到“哪个代理基于哪次授权做了这件事”。

讲者还提到密码学验证。可以把它理解为“带签名的授权证据”：系统不仅记录同意，还要能证明某个身份、某个智能体、某个操作在某个上下文中被允许。可观测性则补上运行时视角，让系统能够展示实际发生了哪些操作、为什么允许、授权证据来自哪里。

3.4 一个可执行的治理回路

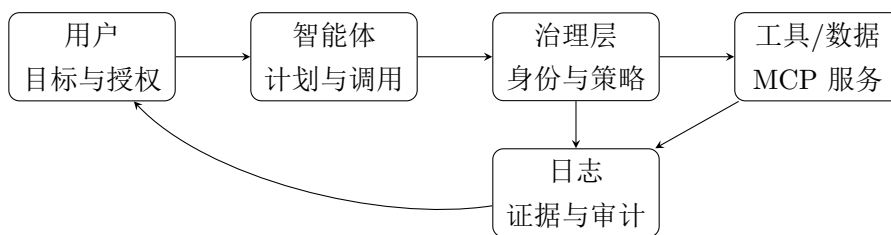


图 4: 适合智能体同意治理的运行回路：授权、计划、策略判断、工具访问和审计证据必须连成闭环。

这个回路解释了为什么视频最后强调“智能体与用户协作”。协作意味着系统把用户意图和边界带入每一步执行，让智能体在可验证身份、可观察证据和可调整策略的约束下行动。用户仍然掌握授权边界，智能体只在边界内扩大行动效率。

3.5 本章小结

Agentic Consent 的难点来自动态执行链。智能体会改变行动路径、扩展工作范围、调用其他组件，并在运行时遇到新场景。治理系统需要上下文感知、身份治理、密码学验证和可观测性，把“曾经点击过同意”升级为“每一步都能解释和证明为何可执行”。

4 细粒度权限：时间、交易与策略

4.1 从粗权限到可执行约束

视频进入实现层后，讲者先从权限开始。传统系统擅长做权限控制，但智能体需要更细的粒度。粗权限像一把总钥匙，给出去以后很难解释“能读但不能写”“能查这一次但不能长期保留”“能访问这个文件夹但不能访问整个驱动器”。智能体执行链越长，粗权限的爆炸半径越大。

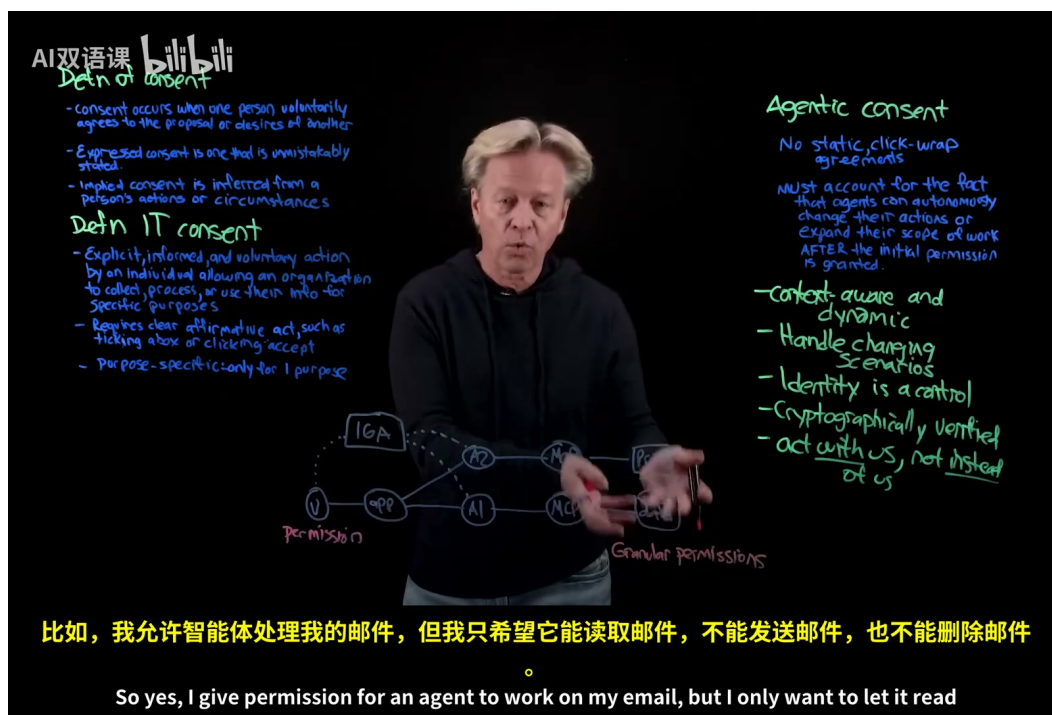


图 5: 邮件场景中的细粒度权限：允许智能体读取邮件，同时限制发送和删除。⁴

邮件例子很直观：用户可以授权智能体处理邮件，但只允许读取，不允许发送，也不允许删除。这里真正要抓住的是动作拆分。读、发、删是三个不同操作，风险等级不同，审计要求也不同。

4.2 时间约束与交易约束

讲者接着提出时间限制和基于交易的访问。理想状态下，权限不应长期有效；它应当只覆盖当前请求、当前交易或当前具体实例。这样设计的好处是，即使一次授权被误用，影响范围也被压缩在有限窗口里。

可以把一次智能体授权形式化为一个授权元组：

$$G = \langle u, a, op, r, p, S, T, \tau, e \rangle$$

⁴视频画面时间区间：00:08:31–00:08:43。

其中：

- u 表示授权用户。
- a 表示被授权智能体。
- op 表示允许执行的操作，例如读取、发送、删除。
- r 表示资源，例如邮箱、文件夹、数据库记录。
- p 表示目的，例如回复邮件、完成报销、查询订单。
- S 表示范围边界，例如只读、某个文件夹、某类数据。
- T 表示有效时间窗口。
- τ 表示交易或工作流实例。
- e 表示证据，例如用户点击、签名令牌或审批记录。

这个公式的作用是把“同意”从一句自然语言压缩成可执行检查点。治理系统每次看到智能体动作，都可以把实际请求与 G 对齐：操作是否匹配，资源是否匹配，时间是否过期，交易是否仍是同一个实例，证据是否存在。

4.3 策略把授权变成系统行为

视频在 00:09:50 之后把身份和治理框架连接到策略。系统识别关键要素：时间约束是什么，交易动作如何执行，需要从哪些细粒度权限里提取判断。随后这些规则进入治理政策，立即开始实施。

策略的工程价值

策略不能沦为合规文档的装饰层。它是把授权边界翻译成运行时判断的执行层：允许、拒绝、降级、要求人工审核、写入日志，都应由策略驱动。

这种设计也把责任分清楚。用户表达意图，智能体提出动作，身份系统证明主体，策略系统判断边界，日志系统留下证据。任何一层缺失，系统都会退回到“信任智能体自己别越界”的脆弱状态。

4.4 本章小结

细粒度权限把智能体授权拆成可检查的动作、资源、目的、范围、时间和交易实例。邮件例子说明了同一资源下不同操作的风险差异；时间和交易约束则把授权限制在短窗口内。治理策略负责把这些边界变成运行时行为，使智能体系统能够执行、拒绝、追问和审计。

5 即时同意、透明度与可撤销授权

5.1 敏感场景需要即时响应

视频最后进入运行时治理。讲者举了一个敏感数据场景：智能体正在处理事务，突然需要访问财务信息或非常个人化的信息。此时如果现有策略没有覆盖，系统就需要即时返回给用户，询问是否允许继续。

这个过程可以称为即时同意。它只应在风险升高、策略缺口出现、授权边界不清楚时触发人工审核，不能演变成每次动作都打断用户。对用户而言，这是一种把控制权重新拿回来的机制；对系统而言，这是把未知场景转化为可记录授权和未来策略的机会。

图 6: 人工审核回路: 智能体遇到策略缺口或敏感操作时, 治理系统回到用户侧请求处理决定。⁵

讲者强调，同意不只驱动当下动作，还会被记录下来，并可能创建新策略。这个点很重要：一次人工审核如果只解决当前请求，系统会反复打扰用户；如果把审核结果转化为边界明确的新策略，未来相似场景就可以自动处理。

5.3 透明度、撤销与修改

⁵视频画面时间区间：00:11:12-00:11:40。

5.4 个性化授权把边界贴近用户意图

视频最后一点是个性化。用户可能允许智能体访问某类数据，却不希望它访问某个区域、文件夹、驱动器或更具体的数据集。这种个性化属于同意治理的一部分，已经超出界面偏好，因为它把授权边界映射到用户真正关心的资源结构上。

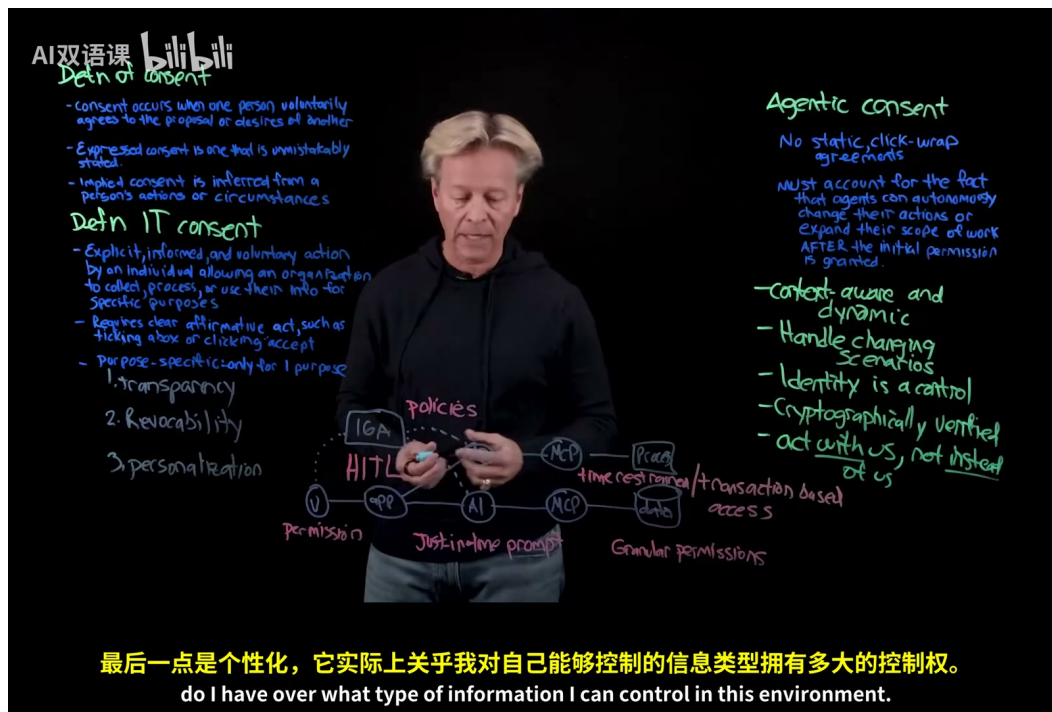


图 7: 收尾阶段的控制面：透明度、可撤销性、个性化、策略和即时提示共同形成持续治理。⁶

活合同

讲者把 Agentic Consent 总结为人与机器之间的“活合同”。它基于身份、意图和当前情境持续更新，让智能体在扩展自主能力时仍然维持信任、安全和治理。

5.5 本章小结

即时同意处理策略缺口和敏感动作，人工审核把灰区转化为明确授权，授权记录又能沉淀为未来策略。透明度让用户看到政策、同意和信息流；撤销与修改让长期授权保持可控；个性化让边界贴近真实资源。视频的最终主张是：智能体授权是一套持续运行的治理机制，必须随自主能力一起扩展。

6 总结与延伸

6.1 核心压缩

这段视频可以压缩成一条主线：当 AI 智能体从“生成内容”进入“执行操作”，同意就从界面确认升级为运行时治理。传统 IT 同意强调用户看见提示并做出肯定性动作；Agentic Consent 还要把身份、意图、上下文、策略、证据和审计放进执行链。

最小模型可以写成三层：

⁶ 视频画面时间区间：00:12:51-00:13:29。

- **表达层：**用户知道目的、范围和期限，并给出明确授权。
- **执行层：**智能体把授权转成具体工具调用、数据访问和操作计划。
- **治理层：**身份、策略、日志、可观测性和人工审核持续检查执行边界。

这三层必须一起工作。只有表达层，系统容易停留在复选框合规；只有执行层，智能体可能高效越界；只有治理层，用户意图又会变成后置审计。真正可用的 Agentic Consent，要让三层在每次高风险动作前后形成闭环。

6.2 对工程实践的启发

第一，权限要按动作拆分。读、写、发、删、转发、共享、保留、训练，应该被视为不同操作，不能粗略归进同一个“访问权限”。

第二，授权要按时间和交易收窄。长期权限应当有可见记录、撤销入口和自动过期策略；一次性任务应优先使用短期令牌或工作流实例绑定。

第三，身份要覆盖人和智能体。只知道“用户登录成功”还不够，系统还要知道哪个智能体、哪个工具、哪个 MCP 服务、哪次策略判断参与了执行。

第四，人工审核应当服务于策略学习。每一次即时同意都应留下结构化记录，帮助系统在未来相似场景中自动允许、自动拒绝或继续追问。

6.3 需要继续追问的问题

- 如何设计授权 UI，既让用户理解真实风险，又不制造弹窗疲劳。
- 如何给智能体身份签发和撤销凭证，使其能跨工具调用保持可验证。
- 如何把自然语言授权转成机器可执行策略，并处理含糊边界。
- 如何审计多智能体链路，证明某个下游动作仍在最初授权范围内。
- 如何把透明度做成用户真正能读懂的记录，避免只产出给合规团队看的日志。

6.4 最终结论

Agentic Consent 的价值在于把“允许智能体行动”变成可持续检查的系统契约。这个契约以用户身份和意图为起点，以细粒度权限和交易边界约束执行，以透明度、撤销、个性化和审计维持长期信任。智能体越自主，治理就越要靠近运行时；系统越自动化，用户可理解、可撤销、可追溯的控制权就越关键。

从规模化角度看，这套机制的实际作用是降低组织把智能体接入真实业务的阻力：权限边界能复用，例外场景能升级，用户选择能记录，审计证据能回放，策略也能随着新场景逐步变厚。